

Ara Proje Gösterimleri

CEN429 Güvenli Programlama — Hafta 7

Dr. Öğr. Üyesi Uğur CORUH · 30.10.2026

Bu hafta: ara proje gösterimleri (RAP1)

- Ders anlatılmaz; her takım **ara raporunu teslim eder** ve **uygulamasını gösterir**
- RAP1 = vizenin **%60**'ı · Quiz-1 = **%40** → $\text{Not_Vize} = 0,6 \cdot \text{RAP1} + 0,4 \cdot \text{QUIZ1}$
- Ayrıntılı rubrik: proje rehberi · sıra, süre, teslim saati: ders sınıfı
-  Geç teslim kabul edilmez

Vize rubriği: beş kriter

Kriter	ÖÇ	Kılavuzda
Güvenlik analizi	1	S2 · S3 arayüz tablosu · S4 tehdit/saldırgan modeli
Veri güvenliği	2	S5 varlık listesi · S7 kabuk matrisi
C/C++ sağlamlaştırma (hardening) ve RASP	3	S9 (temel) · S10
Proje yönetimi	5	S13 süreç, SBOM · GitHub deposu ve plan
Ara rapor	7	Vize bölümlerinin tamamı

Kanıt = kılavuzun ilgili bölümü + kod + test çıktısı; her tehdide karşılık en az bir önlem gösterin.

Rubriğin okunuşu — şema

Rubrik nasıl okunur?

her puan satırı bir kanıta bağlanır



Kanıtı olmayan satır puanlanmaz — 13. haftanın uyum matrisi mantığı burada da geçerli.

Ara raporda hangi bölümler?

Tam	Taslak / kısa / plan
S0 kapak · S2 genel bakış · S3 mimari · S4 tehdit modeli	S1 kapsam (taslak) · S5 varlıklar (taslak)
S7 veri güvenliği · S10 RASP · S13 süreç	S9 sağlamlaştırma (temel) · S12 raporlama (kısa)
	S16 test (plan) · S17 uyum matrisi (taslak)

Finale kalanlar: S6 · S8 · S11 · S14 · S15

RAP1 teslimi — şema

RAP1 (vize) teslimi: ne bekleniyor?

ürünün ilk yarısı + kılavuzun ilk bölümleri

S2 · Ürün ve mimari

bileşenler, arayüzler, güven sınırları

S3 · Arayüzler

her arayüz için doğrulama

S4 · Tehdit modeli

STRIDE + saldırı ağacı

S5 · Varlık listesi

her varlık: konum, koruma şeması

Temel korumalar

AEAD, güvenli silme, girdi doğrulama

RAP1 = 0,7 · vize notu. Kalan 0,3 Quiz-1'den gelir.

Hazırlık kontrol listesi

Hafta	Gösterebilmeniz gereken
1	Depo + plan · S2 · S3 arayüz tablosu · S4 STRIDE + saldırı ağacı · S5 taslak (C/I/I+)
2	Her tehdit → CWE + CVSS v3.1 vektörü
3	S7 algoritma/anahtar/bağlama · kabuk matrisi · CSPRNG · AEAD doğrulama
4	S9 koruma tablosu · CERT bulguları · ASan+UBSan · fuzz sonucu
5	SBOM + tarama · girdi doğrulama tablosu
6	S10 RASP envanteri · tepki politikası · bir atlatma denemesi

Önerilen gösterim akışı

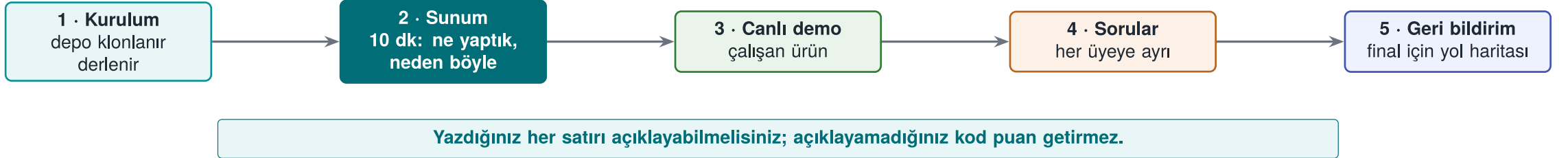
1. **Ürün ve mimari** (S2–S3, ~2 dk): tek şema, güven sınırları
2. **Tehditler ve varlıklar** (S4–S5): en kritik üç tehdit, her birine bir önlem
3. **Canlı gösterim**: en az bir önlem **çalışırken** (ör. şifreli veri, imza doğrulama, RASP tetiklenmesi) — yedek video + hazır komutlarla
4. **Kanıt**: koruma tablosu, sanitizer/fuzz, SBOM — komut + çıktı
5. **Kalan risk ve plan**: finale kadar ne yapılacak? (dürüst analiz puan getirir)

Her önlem için: **Neyi korur? · Nasıl yapıldı? · Nasıl kanıtlandı?**

Gösterim günü akışı — şema

Gösterim günü akışı

toplam 20 dakika · takımın HER üyesi konuşur



Örnek sorular

- Güven sınırını geçen en riskli akış hangisi?
- Bu varlık bellekte ne kadar açık kalıyor, nerede siliniyor?
- Anahtar nereden geliyor, nerede duruyor, ne zaman siliniyor? Nonce tekrar edebilir mi?
- Hangi derleyici koruması kapalı, neden?
- RASP denetimi başarısız olunca ne oluyor?
- SBOM'da zafiyetli bileşen var mı? Etkileniyor musunuz?
- En kritik üç varlığınız, C/I/I+ etiketleri ve yaşam döngüsü nedir?
- Bir tehdide karşı hangi önlem var, nasıl doğrulandı? (tehdit → önlem → kanıt)
- Kalan riskiniz ne, neden kabul edilebilir? (dürüst ve gerekçeli yanıtlayın)

Sık yapılan hatalar

Hata	Neden sorun?
Kılavuz ile kod tutarsız	En ciddi bulgulardan biri
Kanıtsız "güvenli" iddiası	Puanlanmaz
Varlık listesinde anahtar/günlük/kod yok	Listede olmayan korunmuyor
Genel bilgiden tehdit tablosu	Projeye özgü tehditler kaçır
Prova edilmemiş gösterim	Süre boşa gider
Depoda gerçek parola/anahtar/kişisel veri	Ciddi güvenlik hatası; değerler sentetik
Canlı demo yedeksiz çöküyor / kalan risk bölümü boş	Hazırlıksızlık ve dürüst olmayan analiz izlenimi verir

Sık yapılan hatalar — şema

Gösterimde sık yapılan hatalar

değerlendirici kanıt arar, iddia değil

YAPMAYIN

slaytta kod okumak
“çalışıyor” deyip göstermemek
tek kişinin konuşması
kanıtsız “güvenli” iddiası

YAPIN

çalışan demoyu göstermek
kararın GEREKÇESİNİ anlatmak
ölçüm/kanıt sunmak
sınırları dürüstçe söylemek

“Şunu yapamadık, nedeni şu” demek, olmayan bir şeyi var göstermekten iyidir.

Akademik dürüstlük

- Kaynaksız kod/metin, takım dışı çalışma, uydurma sonuç **kabul edilmez**
- Teslim edilen her satır açıklanabilmeli
- Her takım üyesi kendi bölümünü anlatabilmeli; herkese soru sorulabilir

Gösterimden sonra

- Geri bildirimini **bulgu listesi** olarak yazın (bulgu · önem · düzeltme · tarih) → 12. haftanın küçük modeli
- Final bölümleri: S6 · S8 · S11 · S14 · S15 · S16 sonuç · S17

Gösterim bir **kanıt** sunumudur: her iddianın arkasında bir belge, test ya da canlı çıktı olsun.

Gelecek hafta

Hafta 8 — Ara sınav haftası: Quiz-1

- Kapsam: 1–6. haftalar
- Çalışma rehberi ve örnek sorular: 8. hafta sayfası